

CVEs más relevantes de la semana

Del 08/09/2026 al 15/09/2026

Porque el primer paso para defender es conocer las amenazas.



CVE-2026-87534

Descripción: Missing authorization in WebView in Google Chrome on on Android prior to 153.0.8010.36 allowed a remote attacker leveraging social engineering to bypass system access restrictions via crafted network traffic. (Chromium security severity: Medium)

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-862

Tecnología: No especificado

Publicado el: 2026-09-09



CVE-2026-87544

Descripción: Incorrect authorization in Extensions in Google Chrome prior to 153.0.8010.36 allowed a remote attacker to bypass system access restrictions into a privileged page via a crafted HTML page. (Chromium security severity: Low)

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-863

Tecnología: No especificado

Publicado el: 2026-09-09



CVE-2026-21095

Descripción: Heap-based buffer overflow in DNG decoder of libimagecodec.quram.so prior to SMR Sep-2026 Release 1 allows remote attackers to execute arbitrary code.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-122

Tecnología: No especificado

Publicado el: 2026-09-09



CVE-2026-21096

Descripción: Heap-based buffer overflow in JPEG decoder of libimagecodec.quram.so prior to SMR Sep-2026 Release 1 allows remote attackers to execute arbitrary code.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-122

Tecnología: No especificado

Publicado el: 2026-09-09



CVE-2026-86751

Descripción: Snipe-IT before 8.7.0 fails to properly sanitize markdown image syntax in note fields, allowing authenticated users to read arbitrary server files and issue server-side HTTP requests. Attackers can submit markdown image syntax in checkout acceptance notes that survive HTML escaping, are expanded by CommonMark parser, and resolved by laravel-mail-auto-embed via file_get_contents or curl, exfiltrat...

CVSS: 8.5 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:L/A:N

Tipo: CWE-73

Tecnología: No especificado

Publicado el: 2026-09-09



CVE-2026-79941

Descripción: Dell SCG 5.0 Appliance versions prior to 5.36.00.16 and Dell SCG 5.0 Application versions prior to 5.36.00.00, contains an Improper Neutralization of Special Elements used in a Command ('Command Injection') vulnerability. An unauthenticated attacker with remote access could potentially exploit this vulnerability, leading to script injection.

CVSS: 5.3 (MEDIUM)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Tipo: CWE-77

Tecnología: No especificado

Publicado el: 2026-09-09



CVE-2026-79689

Descripción: Dell SCG 5.0 Appliance versions prior to 5.36.00.16 and Dell SCG 5.0 Application versions prior to 5.36.00.00, contains an Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection') vulnerability. An unauthenticated attacker with remote access could potentially exploit this vulnerability, leading to script injection.

CVSS: 5.3 (MEDIUM)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-09-09



CVE-2026-9163

Descripción: Improper neutralization of special elements used in an SQL command ('SQL injection') vulnerability in GIS Informatics GisLab Laboratory Management System allows SQL Injection.

This issue affects GisLab Laboratory Management System: from 1.4.03 before 1.5.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-09-10



CVE-2026-88007

Descripción: Traefik is an open source HTTP reverse proxy and load balancer. From 2.11.0 until 2.11.57 and 3.7.13, the HTTP/3 endpoint ConnContext does not call service.AddTransportOnContext, so kerberosRoundTripper uses a shared backend transport instead of a transport dedicated to each frontend connection. With HTTP/3 enabled, a backend using connection-bound NTLM or Negotiate authentication, and backen...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-287

Tecnología: No especificado

Publicado el: 2026-09-10



CVE-2026-88008

Descripción: Traefik is an open source HTTP reverse proxy and load balancer. From 2.11.26 until 2.11.57 and 3.7.13, Traefik forwards a client-supplied Connection header requesting Upgrade, the Upgrade: h2c token, and HTTP2-Settings to a shared backend. If the backend accepts h2c and returns 101 Switching Protocols, Traefik enters a raw tunnel and no longer applies routers, BasicAuth, ForwardAuth, IPAllowLis...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-444

Tecnología: No especificado

Publicado el: 2026-09-10



CVE-2026-90608

Descripción: A flaw has been found in Totolink A3002MU Hh-B20211125.1046. The affected element is the function formPortFw of the file /boafrm/formPortFw of the component boa. This manipulation of the argument service_type causes buffer overflow. It is possible to initiate the attack remotely. The exploit has been published and may be used.

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-119

Tecnología: No especificado

Publicado el: 2026-09-14



CVE-2026-90680

Descripción: A security flaw has been discovered in D-Link DIR-823G 1.0.2B05_20181207. The impacted element is the function strcpy of the file /HNAP1/SetStaticRouteSettings of the component HNAP1. The manipulation of the argument PAddress/SubnetMask/Gateway results in stack-based buffer overflow. The attack can be launched remotely.

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-119

Tecnología: No especificado

Publicado el: 2026-09-14



CVE-2026-90937

Descripción: froxlor versions before 2.2.5 fail to validate newline characters in subdomain redirect URLs, allowing authenticated customers to inject arbitrary nginx or Apache configuration directives. Attackers can supply URLs containing literal newlines that are written verbatim into vhost config files during cron rebuild, enabling web server configuration corruption, denial of service, or hijacking of HT...

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:L

Tipo: CWE-93

Tecnología: No especificado

Publicado el: 2026-09-14



CVE-2026-90945

Descripción: Crawlai through 0.6.3 uses a hard-coded HMAC-SHA256 secret for JWT token signing that cannot be overridden via configuration or environment variables. Unauthenticated attackers can forge valid administrator tokens to access administrative APIs and execute code on worker nodes.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-321

Tecnología: No especificado

Publicado el: 2026-09-14



CVE-2026-91995

Descripción: pig before 4.1.0 contains an authentication bypass vulnerability in the /register/password endpoint where password verification results are discarded, allowing any value as the current password. Remote attackers can submit a username with an incorrect current password to overwrite any account credential including the admin account and gain full administrative control.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-620

Tecnología: No especificado

Publicado el: 2026-09-15



CVE-2026-91998

Descripción: Casdoor through 4.4.0 contains an authorization bypass vulnerability in the /api/mcp endpoint that allows attackers with any application's clientId and clientSecret to gain unrestricted access to user administration across all organizations. Attackers can enumerate user records including password salts and email addresses, create administrator accounts, modify existing users, and delete them in...

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-863

Tecnología: No especificado

Publicado el: 2026-09-15



CVE-2026-39919

Descripción: Ghostscript before 10.08.0 contains a heap-based buffer overflow vulnerability in the JPEG 2000 output adapter (base/sjpx_openjpeg.c) that allows attackers to cause memory corruption by supplying a crafted PDF containing a JPEG 2000 image with mismatched component subsampling factors. When image components declare different subsampling values, the non-samescale sub-byte-depth output path alloca...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-122

Tecnología: No especificado

Publicado el: 2026-09-15



CVE-2026-91949

Descripción: FreeRDP server versions before 3.31.0 contain a protocol negotiation bypass vulnerability that allows unauthenticated attackers to establish RDSTLS connections despite server policy disabling them. Attackers can send incompatible protocol requests, receive negotiation failures, then complete TLS handshake and enter RDSTLS to bypass pre-authentication transport restrictions.

CVSS: 9.3 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:L/A:N

Tipo: CWE-693

Tecnología: No especificado

Publicado el: 2026-09-15



CVE-2024-58385

Descripción: Yonyou U8 CRM contains an unauthenticated SQL injection vulnerability in the fillbacksettingedit.php configuration endpoint where the DontCheckLogin=1 parameter bypasses authentication and the id parameter is incorporated into SQL queries without sanitization. Attackers can exploit this flaw to execute arbitrary SQL commands and, on Microsoft SQL Server deployments with xp_cmdshell enabled, wri...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-09-15



CVE-2026-89026

Descripción: The Issabel Framework, the web framework supporting Issabel PBX software, before commit b97dbaf contains a hard-coded HS256 JWT signing key in the pbxapi index.php file that is identical across every installation, allowing unauthenticated remote attackers to forge valid bearer tokens. Attackers can use the forged token to call the manager originate endpoint with the System application parameter...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-321

Tecnología: No especificado

Publicado el: 2026-09-15



Resumen del Reporte

CVEs analizados: 20

Promedio CVSS: 9.18

Fuente: nvd.nist.gov

Nos vemos la próxima semana. Hack the Cat ☹

